

DRAFT POLICY PROPOSAL

Prepared and Submitted by:
ISEEWAVES (PRIVATE) LIMITED
Abdullah | Chief Executive Officer
Abbottabad, Pakistan

SUBMITTED TO:
The Government of the Islamic Republic of Pakistan
Ministry of Information Technology & Telecommunication
National Commission for Personal Data Protection

NATIONAL IDENTITY GOVERNANCE POLICY

FOR HUMAN AND ARTIFICIAL INTELLIGENCE SYSTEMS

NIGP-HAI | 2026

Drafted in Reference to the National AI Policy 2025 and the Digital Nation Pakistan Act
Aligned with: EU AI Act (2024) | Colorado AI Law (SB 205) | NIST AI RMF 1.0 | ISO/IEC 27001

CLASSIFICATION: PUBLIC
Islamabad, Pakistan (2026)

PREAMBLE

ISEEWAVES (PRIVATE) LIMITED, respectfully submits this Draft National Identity Governance Policy for Human and Artificial Intelligence Systems (NIGP-HAI) 2026 to the Ministry of Information Technology and Telecommunication and the National Commission for Personal Data Protection for regulatory consideration, deliberation, and adoption. This draft is prepared in recognition of the constitutional obligation of the Government of the Islamic Republic of Pakistan to safeguard the dignity, privacy, and fundamental rights of its citizens; and in acknowledgment that identity whether human or artificial constitutes the foundational trust layer upon which all digital governance, public service delivery, and economic activity is conducted. The unchecked proliferation of artificial intelligence systems, autonomous agents, and machine-readable entities operating across critical national infrastructure presents systemic risks to sovereignty, individual liberty, and institutional integrity that this draft policy is designed to address.

This Policy is enacted in furtherance of the National Artificial Intelligence Policy 2025 promulgated by the Ministry of Information Technology and Telecommunication (MoITT), which, under Pillar Three Secure AI Ecosystem mandated the formulation of a National Authority Trust and Identity Management Policy. However, the 2025 National AI Policy, while visionary in its six-pillar architecture, left the identity governance framework structurally underdeveloped. Section 3.4 of that policy comprised only a broad directive to establish authentication accountability mechanisms, with no operational protocols, no lifecycle governance provisions, and crucially, no framework whatsoever for the governance of non-human and artificial intelligence identities. This Policy constitutes the authoritative and enforceable instrument that fulfils that mandate.

Furthermore, this Policy takes note of multiple evaluative analyses, including assessments by the Pakistan Institute of Development Economics (PIDE), the Digital Rights Foundation (DRF), and the Institute of Strategic Studies Islamabad (ISSI) which have consistently identified the absence of enforceable identity standards, the non-enactment of a Personal Data Protection statute, the absence of a dedicated AI regulatory authority with binding powers, and the failure to address the governance of autonomous and non-human identity systems as critical vulnerabilities in Pakistan's digital governance architecture. This Policy directly and comprehensively addresses each of these deficiencies.

On behalf of ISEEWAVES (PRIVATE) LIMITED, I am pleased to submit this Draft National Identity Governance Policy for Human and Artificial Intelligence Systems to the Ministry of Information Technology and Telecommunication.

Abdullah

Chief Executive Officer, ISEEWAVES (PRIVATE) LIMITED

PART I — LEGISLATIVE AUTHORITY AND INSTITUTIONAL MANDATE

1.1 Constitutional and Statutory Basis

This Policy derives its authority from:

- Article 14 of the Constitution of the Islamic Republic of Pakistan (1973), which guarantees the inviolability of the dignity of man and privacy of home;
- Article 19-A, which confers upon citizens the right to access information in all matters of public importance;
- The National Artificial Intelligence Policy 2025 (MoITT), Pillar Three, Section 3.4;
- The Electronic Transactions Ordinance 2002 (as amended);
- The Prevention of Electronic Crimes Act 2016 (PECA);
- The Personal Data Protection Act 2026 (pending enactment - this Policy anticipates and operationally precedes its formal passage);
- The Digital Nation Pakistan Act (Draft);
- Uraan Pakistan, National Economic Transformation Plan 2024-2029.

1.2 Scope of Application

This Policy applies to:

- All federal ministries, departments, regulatory authorities, and public sector undertakings of the Government of Pakistan;
- All provincial governments and their affiliated digital services to the extent they operate interconnected national identity infrastructure;
- All private sector entities including financial institutions, telecommunications operators, healthcare providers, and technology companies that process, authenticate, or govern digital identities of any category within Pakistani jurisdiction;
- All artificial intelligence systems, autonomous agents, large language model deployments, robotic process automation bots, application programming interfaces (APIs), service accounts, and any other non-human digital identity operating within or interfacing with Pakistani digital ecosystems;
- All foreign entities deploying AI systems or processing Pakistani citizen data within Pakistan or with cross-border data flows affecting Pakistani subjects.

1.3 Extraterritorial Applicability

Any foreign digital entity whether a technology platform, AI-as-a-service provider, or cloud infrastructure operator that offers services to Pakistani residents, processes data pertaining to Pakistani nationals, or deploys automated AI agents within Pakistani digital infrastructure shall be subject to the identity governance obligations stipulated herein, consistent with the principle of effects-

based jurisdiction recognized in international cybersecurity and data protection law. This approach is modelled upon the extraterritorial provisions of the European Union's General Data Protection Regulation (GDPR) and the EU AI Act, which Pakistan recognizes as authoritative international reference frameworks.

PART II — DEFINITIONS AND CLASSIFICATION TAXONOMY

2.1 Authoritative Definitions

For the purposes of this Policy, the following definitions shall bear the meanings assigned herein, and no other construction shall be admitted:

Term	Authoritative Definition
Digital Identity	A structured, verifiable, and unique representation whether biometric, cryptographic, credential-based, or behaviorally derived that enables an entity, human or non-human, to be authenticated, authorized, and held accountable within a digital ecosystem.
Human Identity	A digital identity directly corresponding to a natural person and governed by biometric, documentary, and credential-based verification mechanisms administered through NADRA or equivalent authorized registries.
AI System Identity (AISI)	A structured identity credential assigned to any artificial intelligence system, autonomous agent, large language model deployment, or decision-support engine operating within Pakistani digital infrastructure, enabling its authentication, capability delimitation, and behavioral accountability.
Non-Human Identity (NHI)	Any digital identity not directly corresponding to a natural person, including service accounts, API keys, robotic process automation bots, IoT device credentials, automated pipelines, and AI agent identities.
Identity Security Descriptor (ISD)	A machine-readable, standardized metadata structure associated with every registered identity human or non-human containing classification, authentication strength, privilege scope, behavioral baseline, lifecycle status, risk score, delegation permissions, and known vulnerabilities.
Identity Lifecycle	The complete temporal arc of a digital identity from inception (registration and provisioning), through active deployment (authentication events, authorization exercises, behavioral monitoring), to termination (revocation, archival, and cryptographic invalidation).
Privilege Creep	The unauthorized or undocumented accumulation of access rights and capabilities beyond those originally provisioned to an identity, whether occurring through administrative oversight, system error, or deliberate manipulation.
Behavioral Baseline	A statistically derived and continuously updated model of the expected interaction patterns, access frequencies, data consumption volumes, and operational parameters characterizing a given identity's normal functioning.
Autonomous AI Agent	An AI system capable of independently initiating actions, executing multi-step workflows, accessing external systems, generating outputs, or making decisions without direct per-action human authorization.
Credential Sprawl	The uncontrolled distribution of authentication tokens, API keys, service

	account passwords, or other identity credentials across multiple environments without centralized governance, auditing, or revocation capability.
Zero Trust Architecture (ZTA)	A security paradigm predicated upon the principle that no identity human or non-human shall be presumed trustworthy by virtue of network location or prior authentication, and that every access request shall be evaluated against current risk context, behavioral profile, and minimum-privilege standards.
High-Risk AI Identity	An AI system identity classified as High Risk pursuant to Part IV of this Policy, by virtue of its deployment in critical national infrastructure, healthcare, financial services, judicial systems, law enforcement, or systems making consequential decisions affecting fundamental rights.
National AI Identity Registry (NAIIR)	The centralized, authoritative repository maintained by the National Digital Identity Authority (NDIA) containing the registered Identity Security Descriptors of all AI system identities operating within Pakistani jurisdiction.
Prompt Injection	A category of adversarial attack in which malicious instructions are embedded within input data processed by an AI system, causing the system to deviate from its authorized behavioral parameters and execute unintended or unauthorized actions.

PART III — FOUNDATIONAL PRINCIPLES OF IDENTITY GOVERNANCE

This Policy is anchored in the following foundational principles, which shall govern the interpretation of all provisions herein and shall inform the exercise of regulatory discretion by all competent authorities:

3.1 Principle of Unified Accountability

Human identities and AI system identities shall be governed under a single, unified accountability architecture. The bifurcation of identity governance into separate human-facing and machine-facing regimes, a systemic weakness identified in existing IAM frameworks globally and explicitly absent from Pakistan's National AI Policy 2025 shall be superseded by an integrated governance model in which all identities, regardless of type, are subject to equivalent standards of registration, authentication, monitoring, and revocation.

3.2 Principle of Minimum Privilege

Every identity whether human or artificial shall be provisioned with only the minimum access rights, data permissions, and operational capabilities necessary for the performance of its designated function. Excess privilege constitutes a security liability and shall be treated as a compliance failure subject to mandatory remediation within timelines stipulated in Part VII of this Policy.

3.3 Principle of Continuous Validation

Authentication of identity at the point of system access shall be regarded as necessary but insufficient for the purposes of this Policy. All identities in active deployment shall be subject to continuous behavioral validation, anomaly detection, and real-time risk scoring throughout the duration of each session and across sessions. This principle extends Zero Trust Architecture beyond the authentication gateway to encompass the full duration of operational activity.

3.4 Principle of Lifecycle Accountability

Every identity shall be subject to defined lifecycle governance, encompassing: (a) formal registration and provisioning; (b) periodic revalidation at intervals proportional to risk classification; (c) mandatory suspension protocols upon detection of anomalous behavior or privilege escalation; and (d) timely and cryptographically verifiable termination upon expiry of operational mandate. Orphaned identities — those remaining active beyond their authorized lifecycle shall be treated as critical security vulnerabilities requiring immediate remediation.

3.5 Principle of Transparency and Explainability

All AI system identities operating within Pakistani jurisdiction shall be associated with documented records specifying their purpose, the entities responsible for their governance, their access capabilities, and the decision-making logic underpinning consequential outputs. This principle is aligned with the transparency mandates of the EU AI Act (Articles 13 and 52) and Colorado's AI governance statute (SB 205), which Pakistan adopts as benchmark standards.

3.6 Principle of Human Sovereignty Over AI Systems

No AI system identity shall be granted autonomous decision-making authority over matters affecting fundamental rights, public safety, national security, or individual liberty without documented human oversight mechanisms capable of intervening, overriding, or terminating AI operations. The delegation of authority to AI agents shall be explicit, bounded, time-limited, and subject to revocation at any time by a designated human principal.

3.7 Principle of Proportionality

Regulatory obligations imposed upon identity controllers and processors shall be proportionate to the risk classification of the identity system in question, the sensitivity of data accessed, and the potential consequences of identity compromise. High-risk AI identity deployments shall attract the most rigorous governance requirements, while low-risk operational identities shall be subject to proportionally lighter obligations without compromising accountability infrastructure.

3.8 Principle of Non-Discrimination

Identity governance mechanisms whether for human or AI identities shall not be designed, deployed, or administered in a manner that introduces, perpetuates, or amplifies discrimination on grounds of gender, religion, ethnicity, socioeconomic status, geographic location, or disability. This principle is directly responsive to concerns raised by the Digital Rights Foundation regarding the discriminatory potential of algorithmic systems operating without adequate identity and accountability constraints.

3.9 Principle of Sovereign Data Residency

Identity credentials, behavioral logs, authentication records, and risk assessment data pertaining to Pakistani nationals and AI systems operating within Pakistani jurisdiction shall be stored, processed, and governed within data infrastructure subject to Pakistani sovereign jurisdiction, unless cross-border transfer is expressly authorized pursuant to mechanisms established under the Personal Data Protection Act.

PART IV — IDENTITY CLASSIFICATION FRAMEWORK

This Part establishes the authoritative classification taxonomy applicable to all identities, human and artificial operating within the scope of this Policy. Classification determines the applicable tier of governance obligations, authentication requirements, monitoring intensity, and enforcement consequences.

4.1 Human Identity Classification Tiers

Tier	Identity Category	Authentication Requirement	Revalidation Frequency
H-1 (Standard)	General civilian identity (NADRA CNIC-linked)	Single-factor + NADRA biometric	Annual
H-2 (Enhanced)	Public servants, licensed professionals, financial account holders	MFA mandatory; biometric + OTP	Semi-annual
H-3 (Privileged)	Government officials with access to classified systems, critical infrastructure operators	Hardware token + biometric + behavioral baseline	Quarterly
H-4 (Critical)	Senior government officials, intelligence personnel, national security operators	Multi-layer hardware cryptographic + continuous behavioral monitoring	Monthly

4.2 AI System Identity Classification Tiers

The following AI system identity classification tiers are established in alignment with the risk-based approach of the EU AI Act (Annex III) and adapted to Pakistan's national context. Unlike the EU AI Act, which classifies AI applications, this Policy classifies the identities of AI systems as operational entities with distinct governance obligations:

Classification	Applicable AI System Types	Governance Obligation Level	Registration Requirement
AI-L1 (Critical Risk)	AI systems in national defence, nuclear facility management, public utility command, judicial sentencing support, mass biometric surveillance	Maximum - NDIA prior approval required	Mandatory prior to deployment; NAIIR registration with full ISD
AI-L2 (High Risk)	Healthcare diagnostics, financial credit decisioning, criminal risk profiling, critical infrastructure access control,	Elevated - Conformity assessment + human oversight mandate	Mandatory; third-party audit certificate required

	immigration processing		
AI-L3 (Significant Risk)	Public sector chatbots, automated government correspondence, large-scale content moderation, HR automation systems	Standard - Self-assessment with regulatory disclosure	Mandatory; ISD filing with NDIA within 30 days of deployment
AI-L4 (Limited Risk)	Customer-facing commercial AI, recommendation engines, business intelligence tools, internal enterprise automation	Basic - Transparency disclosure to affected users	Voluntary registration recommended; mandatory upon request by NDIA
AI-L5 (Minimal Risk)	Productivity tools, grammar checkers, content generation assistants with no consequential decision-making authority	Minimal - Code of practice compliance	Voluntary

PART V — INSTITUTIONAL GOVERNANCE ARCHITECTURE

The effective implementation of this Policy requires the establishment of a dedicated, technically competent, and operationally independent regulatory architecture. Pakistan's National AI Policy 2025 identified NADRA, the NCPDP, and a proposed AI Directorate as relevant institutions but did not establish a unified identity governance authority. This Policy remedies that gap through the following institutional architecture:

5.1 National Digital Identity Authority (NDIA)

There is hereby established the National Digital Identity Authority (NDIA) as a statutory body under the Ministry of Information Technology and Telecommunication, with the following constitution, mandate, and powers:

5.1.1 Mandate of the NDIA

- Serve as the apex regulatory authority for digital identity governance in Pakistan, exercising jurisdiction over human, AI system, and non-human identity categories;
- Administer and maintain the National AI Identity Registry (NAIIR) and the National Human Digital Identity Database (NHDIDB) as integrated systems under unified governance;
- Issue, amend, suspend, and revoke Identity Security Descriptors (ISDs) for all registered identity categories;
- Conduct conformity assessments for AI-L1 and AI-L2 classified AI system identities prior to deployment authorization;
- Exercise enforcement powers including the issuance of compliance notices, administrative penalties, deployment suspension orders, and referrals to the Federal Investigation Agency (FIA) for criminal investigations;
- Develop, maintain, and update technical standards for identity authentication, behavioral monitoring, credential management, and lifecycle governance;
- Engage with international identity governance frameworks, including the EU AI Act implementation authorities, the US NIST AI RMF, and the Global Partnership on Artificial Intelligence (GPAI), to ensure Pakistan's standards remain interoperable and internationally recognized.

5.1.2 Composition of the NDIA Governing Board

- Chair: Secretary, Ministry of Information Technology and Telecommunication;
- Member: Director General, NADRA;
- Member: Chairperson, National Commission for Personal Data Protection (NCPDP);
- Member: Director General, National Telecom Corporation (NTC);
- Member: Representative, State Bank of Pakistan (for financial identity standards);
- Member: Representative, Pakistan Telecommunication Authority (PTA);

- Member: Two independent technical experts in cybersecurity and AI governance, appointed by the Federal Cabinet;
- Member: One representative from civil society organizations with expertise in digital rights;
- Member: Representative from the private technology sector, nominated by P@SHA.

5.2 The National AI Identity Registry (NAIIR)

The NAIIR shall constitute the authoritative, immutable, and continuously updated register of all AI system identities operating within Pakistani jurisdiction. The Registry shall:

- Maintain a complete Identity Security Descriptor (ISD) for each registered AI system identity;
- Generate and assign a unique National AI Identity Number (NAIIN) to each registered system, serving as the primary identifier for all regulatory, audit, and enforcement purposes;
- Record all authentication events, capability modifications, behavioral anomaly flags, risk score adjustments, and lifecycle transitions for each registered identity;
- Be accessible to authorized regulatory authorities, law enforcement agencies, and designated security auditors, subject to appropriate access controls;
- Publish a publicly accessible, privacy-protected summary index of AI-L2 and above registered identities, consistent with the transparency obligations of this Policy and the EU AI Act's database of high-risk AI systems (Article 71).

5.3 The AI Identity Security Operations Center (AI-ISOC)

The NDIA shall establish and operate an AI Identity Security Operations Center (AI-ISOC), functioning on a continuous basis, responsible for:

- Real-time monitoring of behavioral anomalies across registered AI system identities;
- Automated risk score recalculation upon detection of deviation from established behavioral baselines;
- Coordination with the National Computer Emergency Response Team (NCERT) upon detection of identity compromise events;
- Management of the national AI identity threat intelligence sharing platform, enabling regulated entities to receive and contribute information regarding identity-based threats targeting AI systems.

PART VI — THE IDENTITY SECURITY DESCRIPTOR (ISD) STANDARD

The Identity Security Descriptor (ISD) constitutes the foundational technical standard of this Policy. Every identity human or artificial is subject to mandatory registration under Part IV shall be associated with a continuously maintained ISD conforming to the specification set forth herein. The ISD serves simultaneously as a governance record, a risk assessment instrument, and an operational access control parameter.

6.1 Mandatory ISD Data Fields - All Identity Types

ISD Field	Mandatory For	Field Specification
Identity Type	All	Enumerated value: Human AI Agent Autonomous System API Service Account RPA Bot IoT Device
Unique Registry Identifier	All	NAIIN (for AI systems) or NADRA Biometric Reference Number (for human identities)
Classification Tier	All	H-1 through H-4 (human) or AI-L1 through AI-L5 (artificial)
Principal Controller	All	Legal entity or natural person bearing governance accountability for the identity
Authentication Strength Profile	All	Documented authentication mechanisms in operation, mapped to NIST SP 800-63 assurance levels
Privilege Scope Matrix	All	Enumerated list of data categories, system resources, and action permissions authorized to the identity
Behavioral Baseline Parameters	All	Statistical profile of expected activity patterns, updated on rolling 30-day basis
Current Risk Score	All	Numerical score (0-100) calculated pursuant to the Risk Scoring Model in Part VII
Lifecycle Status	All	Active Suspended Under Review Pending Revocation Terminated
Registration Date and Authority	All	ISO 8601 timestamp and NDIA registration certificate reference
Last Revalidation Timestamp	All	Date of most recent identity revalidation event
Incident History Log Reference	All	Pointer to associated incident log in NAIIR or NHDIDB
AI Model Architecture Summary	AI Systems only	Model type, training data provenance statement, deployment purpose, and capability envelope
Human Oversight Mechanism	AI-L1, AI-L2	Documented protocol specifying designated human oversight officer and override capability

Delegation Chain	AI Systems only	Complete record of authority delegations from human principal to AI system
Prompt Injection Vulnerability Assessment	AI Systems only	Date of last adversarial robustness evaluation and findings summary

PART VII — RISK SCORING, BEHAVIORAL MONITORING, AND CAPABILITY RESTRICTION LOGIC

7.1 Dynamic Risk Scoring Model

All identities subject to this Policy shall be assigned a continuously updated Risk Score on a scale of 0 (minimal risk) to 100 (critical risk), calculated using the following composite formula:

Risk Score = (0.30 × Behavioral Anomaly Index) + (0.25 × Privilege Exposure Factor) + (0.20 × Vulnerability Exposure Score) + (0.15 × Authentication Weakness Indicator) + (0.10 × Lifecycle Compliance Deficiency)

Each component of the Risk Score shall be computed as follows:

- Behavioral Anomaly Index (BAI): Deviation of current activity patterns from established behavioral baseline, expressed as a normalized anomaly score computed by the AI-ISOC continuous monitoring engine;
- Privilege Exposure Factor (PEF): Ratio of provisioned access rights to functionally exercised access rights, penalizing identities with significant unused but active privilege;
- Vulnerability Exposure Score (VES): Composite score based on known unpatched vulnerabilities, unresolved security findings, and outstanding conformity assessment deficiencies;
- Authentication Weakness Indicator (AWI): Assessment of authentication mechanism strength relative to classification tier requirements, penalizing sub-standard implementations;
- Lifecycle Compliance Deficiency (LCD): Elapsed time since last mandatory revalidation, expressed as a fraction of the required revalidation interval.

7.2 Risk-Proportionate Capability Restriction Protocols

Upon computation of a Risk Score, the following mandatory operational responses shall be automatically triggered:

Risk Band	Score Range	Automated System Response	Human Oversight Obligation
Low (Green)	0 – 25	Normal operation; background behavioral monitoring continues	No immediate action required; quarterly review
Moderate (Amber)	26 – 50	Increased logging frequency; non-critical privilege suspension; step-up authentication triggered for	Review within 15 business days; remediation plan required

		sensitive operations	
Elevated (Orange)	51 – 74	Temporary restriction of data exfiltration capabilities; enhanced real-time session monitoring; mandatory step-up re-authentication every 4 hours	Security review within 48 hours; NDIA notification required
High (Red)	75 – 89	Suspension of autonomous action capabilities; restriction to read-only access pending investigation; immediate NDIA notification; legal hold on logs	Principal human officer accountability; NDIA incident report within 24 hours
Critical (Black)	90 – 100	Immediate identity suspension; API key revocation; session termination across all active instances; cryptographic credential invalidation; NAIIR status updated to Suspended	Mandatory NDIA enforcement engagement; FIA referral if criminal nexus identified; public disclosure obligation for AI-L2 and above systems

PART VIII — HUMAN IDENTITY GOVERNANCE STANDARDS

8.1 National Digital Identity Infrastructure

NADRA shall serve as the primary registration authority for all human digital identities within Pakistani jurisdiction. The CNIC (Computerized National Identity Card) system shall be extended to incorporate a National Digital Identity Credential (NDIC), which shall function as the foundational authentication token for all government digital services, financial account access, and any AI-mediated system that makes consequential decisions affecting the credential holder. The NDIC shall be FIDO2-compliant, cryptographically secured, and capable of supporting selective disclosure to minimize unnecessary personal data sharing.

8.2 Multi-Factor Authentication Mandate

The following categories of system access shall mandatorily require multi-factor authentication (MFA) as a minimum, with authentication strength requirements escalating per classification tier:

- All government digital service portals (minimum H-2 authentication standards);
- All financial institution account access (minimum H-2 authentication standards);
- All critical infrastructure operator system access (H-3 authentication standards);
- All systems with access to personal health, legal, or national security data (H-3 minimum, H-4 for classified national security systems).

8.3 Deepfake and AI Impersonation Countermeasures

Given the exponential growth of AI-generated synthetic media capable of impersonating natural persons through voice, video, and text modalities, a threat comprehensively documented in FBI Internet Crime Reports and ENISA Threat Landscape analyses. The following countermeasures are hereby mandated:

- All government video conferencing and remote authentication systems shall integrate certified liveness detection and deepfake detection capabilities by the implementation deadline specified in Part XI;
- All AI-generated communications purporting to originate from government officials, financial institutions, or regulatory authorities shall carry a verifiable cryptographic attestation;
- Organizations subject to this Policy that suffer confirmed deepfake-based identity fraud shall be required to notify NDIA within 72 hours and affected individuals within 7 days of confirmed detection;
- The NDIA shall maintain and publish a national register of certified deepfake detection tools approved for use within regulatory compliance programs.

8.4 Credential Lifecycle Management for Human Identities

All organizations managing human identities shall implement the following lifecycle governance protocols:

- Immediate revocation of access credentials upon termination of employment, contract expiry, or disciplinary action;
- Quarterly access rights reviews for H-3 and H-4 classified identities, semi-annual reviews for H-1 and H-2;
- Dormancy detection protocols: any human identity inactive for more than 90 consecutive days shall automatically transition to suspended status pending reactivation verification;
- Prohibition on the sharing of individual identity credentials between multiple natural persons, including within the same organizational role.

PART IX — AI SYSTEM IDENTITY GOVERNANCE STANDARDS

9.1 Mandatory Pre-Deployment Registration (AI-L1 and AI-L2)

No AI system classified as AI-L1 (Critical Risk) or AI-L2 (High Risk) under Part IV of this Policy may be deployed within Pakistani jurisdiction without prior registration in the National AI Identity Registry (NAIIR) and issuance of a valid National AI Identity Number (NAIIN). Applications for NAIIN issuance shall be submitted to the NDIA no less than 60 days prior to intended deployment, and shall be accompanied by:

- A complete Identity Security Descriptor (ISD) conforming to Part VI specifications;
- A third-party conformity assessment report conducted by an NDIA-accredited assessment body;
- A documented human oversight protocol identifying named human oversight officers and override mechanisms;
- A data protection impact assessment (DPIA) conducted in accordance with the Personal Data Protection Act;
- Comprehensive documentation of training data provenance, model architecture, capability boundaries, and known limitations;
- An adversarial robustness evaluation addressing prompt injection, data poisoning, model extraction, and capability boundary violation risks.

9.2 Post-Deployment Registration (AI-L3)

AI systems classified as AI-L3 (Significant Risk) shall file a complete ISD with the NDIA within 30 calendar days of deployment. Failure to comply with this registration obligation shall constitute a Tier 2 compliance violation subject to the penalties specified in Part X.

9.3 Non-Human Identity (NHI) Credential Governance

One of the most critical and systematically overlooked vulnerabilities in Pakistan's current digital governance architecture explicitly absent from the National AI Policy 2025, the PECA 2016, and all existing NADRA identity frameworks is the unregulated proliferation of non-human identity credentials. This Policy establishes the following mandatory NHI governance standards:

9.3.1 Credential Inventory Mandate

All organizations subject to this Policy shall maintain a complete, continuously updated inventory of all non-human identity credentials, including API keys, service account passwords, OAuth tokens, SSH keys, certificates, and automated pipeline credentials. This inventory shall be:

- Stored in an NDIA-approved privileged access management (PAM) vault;
- Subject to automated discovery scanning at minimum monthly frequency;

- Submitted to NDIA in summarized form as part of annual compliance attestations;
- Made available for inspection by NDIA auditors upon request.

9.3.2 Credential Rotation Standards

Organizations shall enforce the following mandatory credential rotation schedules for non-human identity credentials:

- API keys and OAuth tokens with access to sensitive personal data: 90-day maximum validity;
- Service account passwords: 180-day maximum validity with complexity requirements equivalent to NIST SP 800-63B AAL2 standards;
- Cryptographic certificates: Annual renewal unless a shorter validity period is mandated by the issuing certificate authority;
- Long-lived automation credentials: Maximum 12-month validity with automated expiry and rotation workflows.

9.3.3 Prohibition on Embedded Credentials

Effective from the implementation deadline specified in Part XI, the embedding of plaintext credentials including API keys, passwords, or cryptographic secrets within source code repositories, configuration files, container images, or CI/CD pipeline definitions shall constitute a Tier 1 compliance violation under this Policy, regardless of whether the repository is publicly or privately hosted. Organizations shall implement secrets management solutions compliant with NDIA technical standards.

9.4 AI Agent Delegation Framework

Given the unique risk profile of autonomous AI agents systems capable of initiating multi-step actions across multiple platforms without per-action human authorization this Policy establishes the following delegation governance framework:

- Every delegation of authority from a human principal to an AI agent shall be documented in a Delegation Authority Record (DAR), specifying: the scope of delegated authority; temporal boundaries; permitted action categories; prohibited action categories; and the designated human oversight officer responsible for monitoring;
- No AI agent shall be delegated authority exceeding that held by the delegating human principal (no privilege elevation through delegation);
- Delegations to AI-L1 and AI-L2 classified agents shall require NDIA notification and shall be time-limited to a maximum of 90 days without renewal;
- AI agents shall be technically prevented from re-delegating their delegated authority to other AI agents or systems without explicit human principal authorization (AI-to-AI delegation chain control);
- Upon termination of any delegation, all associated authentication tokens and session credentials shall be immediately and verifiably invalidated.

9.5 Prompt Injection and Adversarial Attack Governance

AI systems classified as AI-L2 and above that interact with external inputs whether user inputs, API responses, database queries, or web content shall implement documented defenses against prompt injection attacks as catalogued in the OWASP Top 10 for LLM Applications. Organizations deploying such systems shall:

- Conduct adversarial robustness evaluations at minimum every six months and upon any significant model update;
- Implement input validation, output filtering, and privilege separation architectures to contain the blast radius of any successful prompt injection attack;
- Maintain incident response playbooks specifically addressing AI identity compromise scenarios resulting from adversarial attacks;
- Report confirmed prompt injection incidents resulting in unauthorized data access or action execution to NDIA within 48 hours.

PART X — ENFORCEMENT, PENALTIES, AND REMEDIATION

10.1 Compliance Violation Classification

Violations of this Policy shall be classified into three enforcement tiers based on severity, systemic impact, and culpability:

Tier 1 — Critical Violations

Tier 1 violations represent fundamental breaches of identity governance with potential for severe harm to individuals, national security, or critical infrastructure. These include:

- Deployment of AI-L1 or AI-L2 systems without NAIIN registration or NDIA approval;
- Embedding of plaintext credentials in production code or repositories;
- Failure to report confirmed identity breach events within the prescribed notification period;
- Deliberate falsification of Identity Security Descriptor data;
- AI system deployment in excess of registered capability boundaries.

Penalties for Tier 1 violations: Administrative fine of PKR 50 million to PKR 500 million, or 4% of annual global turnover of the violating entity, whichever is greater; mandatory deployment suspension pending remediation; and referral to FIA for potential criminal prosecution under PECA 2016.

Tier 2 — Significant Violations

Tier 2 violations represent material failures of identity governance that create identifiable security exposure. These include:

- Failure to register AI-L3 systems within the 30-day post-deployment period;
- Non-compliance with mandatory credential rotation schedules;
- Failure to maintain complete NHI credential inventories;
- Orphaned identity accumulation exceeding 5% of total identity inventory without documented remediation plan;
- Sub-standard authentication implementations relative to classification tier requirements.

Penalties for Tier 2 violations: Administrative fine of PKR 5 million to PKR 50 million; mandatory remediation order with 30-day compliance deadline; public disclosure of violation status in NDIA enforcement register.

Tier 3 — Administrative Violations

Tier 3 violations represent procedural non-compliance without immediate security consequence. These include:

- Late submission of annual compliance attestations;
- Incomplete ISD data fields;

- Failure to appoint a designated AI Identity Compliance Officer.

Penalties for Tier 3 violations: Administrative fine of PKR 500,000 to PKR 5 million; compliance notice with 60-day remediation period.

10.2 Appeals and Due Process

Any entity subject to an enforcement action under this Policy shall have the right to appeal the NDIA's determination to the Information Technology Tribunal within 30 days of service of the enforcement notice. Appeals shall not operate as automatic stays of enforcement action unless the Tribunal specifically orders interim relief following assessment of prima facie grounds. The NDIA shall be required to respond to all appeals within 45 days.

10.3 Whistleblower Protection

Any individual who, in good faith, reports a violation of this Policy to the NDIA shall be afforded whistleblower protection under mechanisms equivalent to those available under the Whistleblowers Protection Act 2017, extended to cover digital identity and AI system governance disclosures.

PART XI — IMPLEMENTATION TIMELINE AND PHASED ROLLOUT

Cognizant of the implementation challenges identified in PIDE's assessment of Pakistan's National AI Policy 2025 including weak institutional capacity, infrastructure constraints, and historically ambitious timelines that have proven difficult to execute. This Policy adopts a phased implementation approach calibrated to realistic organizational capacity:

Phase	Timeline	Key Deliverables	Lead Authority
Phase 1: Foundation	Q1–Q2 2026 (Months 1–6)	Establishment of NDIA; enactment of legal mandate; appointment of NDIA Board; initiation of NAIIR architecture design; publication of ISD technical standards; stakeholder consultation on classification tiers	MoITT
Phase 2: Registration Activation	Q3–Q4 2026 (Months 7–12)	Launch of NAIIR for voluntary AI-L2–L3 registration; mandatory registration of all government-deployed AI systems; issuance of first NAIIN batch; publication of accredited conformity assessment body register; initiation of NHI inventory audit for government entities	NDIA
Phase 3: Enforcement Commencement	Q1–Q2 2027 (Months 13–18)	Mandatory registration enforcement for AI-L1 and AI-L2 private sector systems; commencement of penalty regime for Tier 1 and Tier 2 violations; AI-ISOC operational; national deepfake detection tool register published; first annual compliance attestation cycle	NDIA + FIA
Phase 4: Full Compliance	Q3 2027–Q4 2028 (Months 19–36)	Universal compliance enforcement across all classification tiers; international interoperability agreements with EU and GPAI; first comprehensive Policy review; NAIIR public summary index published; AI identity governance integrated into national cybersecurity strategy	NDIA + MoITT + Ministry of Foreign Affairs

PART XII — INTERNATIONAL ALIGNMENT AND COMPARATIVE FRAMEWORK

Pakistan's National AI Policy 2025, while expressing commitment to international alignment, has yet to specify the mechanisms through which Pakistani identity governance standards will achieve interoperability with global frameworks. This Policy addresses that deficit through the following comparative alignment architecture:

International Framework	Relevant Provisions Adopted	Pakistan Adaptation
EU AI Act (2024)	Risk-based AI system classification (Annex III); conformity assessment obligations; human oversight mandates for high-risk systems; public database of high-risk AI systems (Art. 71); transparency obligations for AI-generated content (Art. 52)	Five-tier AI identity classification (AI-L1 through AI-L5) adapted to Pakistan's governance capacity and deployment context; NAIIR as equivalent to EU AI database; phased conformity assessment regime calibrated to domestic assessment capacity
Colorado AI Law (SB 205)	Developer and deployer obligations for consequential decisions; algorithmic discrimination impact assessments; transparency to affected consumers; risk management documentation requirements	Mandatory human oversight protocols for AI-L1/L2 systems; prohibition on algorithmic discrimination in public service delivery AI systems; consumer notification requirements adapted for Pakistani legal framework
NIST AI RMF 1.0	Govern, Map, Measure, Manage framework for AI risk; behavioral monitoring; continuous evaluation standards	Risk Scoring Model (Part VII) aligned with NIST Measure function; ISD standard aligned with NIST Govern function; AI-ISOC operations aligned with NIST Manage function
ISO/IEC 27001 & 27701	Information security management; privacy information management; identity and access management controls	NDIA technical standards for PAM, credential management, and NHI governance derived from ISO/IEC control frameworks
NIST SP 800-63 (Digital Identity)	Authentication assurance levels (AAL1, AAL2, AAL3); identity proofing levels; federation standards	Human identity classification tiers (H-1 through H-4) mapped to NIST AAL levels; NDIC credential design standards aligned with AAL2 minimum

PART XIII — CRITICAL GAPS IN PAKISTAN'S CURRENT FRAMEWORK ADDRESSED BY THIS POLICY

This Part formally records the systemic deficiencies in Pakistan's pre-existing identity governance architecture that this Policy is designed to remedy, drawing upon the analytical findings of PIDE (Knowledge Brief 136, 2025), ISSI (Issue Brief, 2025), and DRF's analysis of Pakistan's National AI Policy 2025:

13.1 Absence of Non-Human Identity Governance

Pakistan's National AI Policy 2025 contains no provision whatsoever for the governance of non-human identities a category that, by industry estimates, now outnumbers human identities by more than 40:1 in enterprise digital environments. Service accounts, API keys, robotic process automation credentials, and AI agent identities were entirely absent from Pakistan's identity governance discourse prior to this Policy. This Policy establishes the first comprehensive NHI governance framework in Pakistani regulatory history, directly addressing what multiple analysts have characterized as the most acute unaddressed vulnerability in the country's digital security architecture.

13.2 Unenforced Ethical AI Principles

The National AI Policy 2025 articulates admirable ethical principles fairness, transparency, accountability, non-discrimination but, as PIDE's analysis explicitly notes, 'ethical principles exist but no enforcement or oversight mechanism' has been established. This Policy transforms ethical aspirations into legally enforceable obligations by creating the NDIA as a body with binding regulatory authority, establishing a penalty regime with meaningful financial consequences, and designating mandatory compliance mechanisms tied to the Identity Security Descriptor framework.

13.3 The Personal Data Protection Legislative Vacuum

Pakistan's Personal Data Protection Bill has been 'pending' since at least 2023, creating a legislative vacuum that allows both human and AI-mediated data processing to occur without adequate accountability mechanisms. This Policy operates as an anticipatory instrument, establishing identity governance standards that will be fully compatible with the expected Personal Data Protection Act while providing immediately operative protections that do not depend upon that statute's enactment.

13.4 Absence of Behavioral Accountability Post-Authentication

Existing Pakistani identity systems including NADRA's CNIC infrastructure, PTA's device registration systems, and the SECP's financial identity frameworks are exclusively concerned with point-of-access authentication. None extend to continuous behavioral monitoring, anomaly detection, or post-

authentication accountability. The zero-trust continuous validation mandate established in Part III and operationalized through the AI-ISOC framework in Part V represents a fundamental architectural advancement beyond any existing Pakistani identity governance instrument.

13.5 No AI Identity Lifecycle Governance

Neither the National AI Policy 2025 nor any existing regulatory instrument in Pakistan establishes lifecycle governance for AI system identities. AI systems are currently deployed, modified, and decommissioned without any identity governance framework tracking their operational status, access rights, or decommissioning compliance. The orphaned AI identity problem whereby AI systems remain active with full access rights long after their intended operational lifecycle is entirely unaddressed in the pre-existing framework. Part IX of this Policy establishes the first mandatory AI identity lifecycle governance requirements in Pakistani regulatory history.

PART XIV — POLICY REVIEW, AMENDMENT, AND SUNSET PROVISIONS

This Policy shall be subject to comprehensive review at two-year intervals from the date of its enactment. The review process shall be conducted by the NDIA in consultation with the AI Council established under the National AI Policy 2025, and shall specifically assess:

- Technological developments in AI system architecture that necessitate classification taxonomy revisions;
- Effectiveness of the Risk Scoring Model in accurately predicting identity-based security incidents;
- Adequacy of penalty levels in deterring non-compliance, with reference to comparative enforcement data from EU and UK jurisdictions;
- Progress towards international interoperability with EU AI Act implementation mechanisms;
- Emerging categories of non-human identity not adequately covered by current taxonomy;
- Civil society and affected communities' assessment of the Policy's human rights implications.

Material amendments to this Policy shall require the approval of the Federal Cabinet and shall be preceded by a minimum 60-day public consultation period during which civil society organizations, industry associations, academic institutions, and international bodies may submit formal representations.

PART XV — DECLARATION OF POLICY EFFECTIVENESS

ISEEWAVES Private Limited proposes that this National Identity Governance Policy for Human and Artificial Intelligence Systems (NIGP-HAI) 2026, upon review and acceptance by the Ministry of Information Technology and Telecommunication and the National Commission for Personal Data Protection, be enacted into force through signature by the Federal Minister for Information Technology and Telecommunication and publication in the Official Gazette of Pakistan. It is further proposed that all regulated entities be afforded the phase-in periods specified in Part XI before mandatory compliance obligations become enforceable, with the exception that this transitional accommodation shall not apply to Tier 1 compliance violations, which shall be enforceable from the date of formal Policy enactment.

The Government of Pakistan, through this Policy, affirms its recognition that identity whether of a citizen, a civil servant, or an autonomous artificial intelligence system is not merely a technical credential but a trust relationship bearing accountability, rights, and obligations. The governance of identity is, therefore, governance itself: the foundational act of a sovereign state securing the integrity of its digital public sphere for the benefit of all its people.

Draft Prepared and Submitted by ISEEWAVES (PRIVATE) LIMITED

For Submission to: Ministry of Information Technology & Telecommunication | National Commission for
Personal Data Protection

Islamabad | 2026

REFERENCES AND AUTHORITATIVE SOURCES

1. Ministry of Information Technology and Telecommunication, Government of Pakistan. National Artificial Intelligence Policy 2025. Islamabad: MoITT, 2025.
2. Pakistan Institute of Development Economics (PIDE). Will AI Transform Pakistan? Assessing the 2025 National Policy. Knowledge Brief No. 136. Islamabad: PIDE, November 2025.
3. Digital Rights Foundation (DRF). DRF Analysis: Pakistan's National AI Policy 2025. Lahore: DRF, August 2025.
4. Institute of Strategic Studies Islamabad (ISSI). Pakistan's National AI Policy 2025: Developing AI Ecosystem and Ethical Data Governance. Issue Brief. Islamabad: ISSI, 2025.
5. European Union. Regulation (EU) 2024/1689 of the European Parliament and of the Council - Artificial Intelligence Act. Official Journal of the European Union, 2024.
6. State of Colorado. Senate Bill 205 (SB 24-205): Concerning Consumer Protections in Interactions with Artificial Intelligence Systems. Colorado General Assembly, 2024.
7. National Institute of Standards and Technology (NIST). Artificial Intelligence Risk Management Framework (AI RMF 1.0). Gaithersburg, MD: NIST, 2023.
8. National Institute of Standards and Technology (NIST). Digital Identity Guidelines (SP 800-63B). Gaithersburg, MD: NIST, 2017 (rev. 2022).
9. International Organization for Standardization. ISO/IEC 27001:2022 - Information Security Management Systems - Requirements. Geneva: ISO, 2022.
10. OWASP Foundation. OWASP Top 10 for Large Language Model Applications. Version 1.1. OWASP, 2025.
11. Verizon Enterprise Solutions. Data Breach Investigations Report 2025. New York: Verizon, 2025.
12. European Union Agency for Cybersecurity (ENISA). ENISA Threat Landscape 2025. Heraklion: ENISA, 2025.
13. Gartner, Inc. Identity and Access Management Market Report 2025. Stamford, CT: Gartner, 2025.
14. Identity Defined Security Alliance (IDSA). 2025 Trends in Securing Digital Identities Report. IDSA, 2025.
15. Government of Pakistan. Prevention of Electronic Crimes Act 2016 (PECA). Islamabad: National Assembly Secretariat, 2016.
16. Government of Pakistan. Electronic Transactions Ordinance 2002 (as amended). Islamabad: Ministry of Law, 2002.
17. UNESCO. Recommendation on the Ethics of Artificial Intelligence. Paris: UNESCO, 2021.
18. Global Partnership on Artificial Intelligence (GPAI). AI Governance and Responsible Innovation: GPAI Summit Report. GPAI, 2024.

Principal Author & Policy Architect: Abdullah, CEO, ISEEWAVES (PRIVATE) LIMITED

© 2026 ISEEWAVES (PRIVATE) LIMITED. This document is a draft policy proposal submitted for regulatory consideration. All intellectual property rights in this draft, including its research, framework design, and policy architecture, vest in

ISEEWAVES (PRIVATE) LIMITED. Reproduction for governmental review, academic citation, and non-commercial research purposes is permitted with full attribution to ISEEWAVES (PRIVATE) LIMITED.